SIZMA TESTİ RAPORU

Rapor Tarihi	07/10/2026
Hazırlayan	Ömer Faruk Baysal
Test Hedefi	PortSwigger Web Academy Lab

1. Vertical privilege escalation

Bu raporda, PortSwigger Web Security Academy'de yer alan dikey yetki yükseltmeleri ile alakalı 6 farklı durum ele alınmıştır.

2. Yönetici Özeti

Yapılan güvenlik testinde, hedef uygulamanın yetki kontrollerinde (access control) ciddi eksiklikler tespit edilmiş ve normal/yetkisiz bir kullanıcının yönetici (admin) ayrıcalıklarına erişebildiği gösterilmiştir. Zafiyetin altı farklı biçimde ortaya çıktığı gözlenmiştir: yönetim panelinin hiç korunmaması, panelin yalnızca tahmin edilemez bir URL ile "gizlenmesi" (security through obscurity), kullanıcı rolünün bir istek parametresi/çerezi ile kontrol edilebilmesi, rol bilgisinin profil güncelleme isteğiyle değiştirilebilmesi (mass assignment), ve yetki kontrolünün yalnızca belirli bir URL yoluna ya da HTTP metoduna bağlı olması nedeniyle atlatılabilmesi.

Her durumda, yetkisiz bir kullanıcının yönetici işlevlerine erişip test için istenen kullanıcıyı (carlos) silebildiği kavram kanıtı (PoC) ile doğrulanmıştır. Yetkisiz yönetici erişimi, kullanıcı verilerinin ve sistem bütünlüğünün tümüyle tehlikeye girmesine yol açabileceğinden zafiyetin ivedilikle giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

Durum 1: Unprotected admin functionality

İlgili hedef sitenin uzantısına /robots.txt eklendiğinde karşılaşılan yanıttaki istenmemesi istenen hedefe yönledirilme yapıldığında admin paneline erişliebildiği tespit edilmiştir. Bu zafiyetin kullanıcıları silme gibi sonuçlara yol açabileceği PoC adımlarıyla kanıtlanmıştır.

Durum 2: Unprotected admin functionality with unpredictable URL

Hedef sitenin login sayfasının yanıtı incelendiğinde <script></script> etikekitinin içinde admin sayfasıyla ilgili bir yönlendirme işlevi tespit edilmiş olup bu yönlendirmeyi kullanarak admin pa paneline erişliebildiği tespit edilmiştir. Bu zafiyetin kullanıcıları silme gibi sonuçlara yol açabileceği PoC adımlarıyla kanıtlanmıştır.

Durum 3: User role controlled by request parameter

Hedef sitenin login isteği istelendiğinde cookie parametresindeki admin değişkeninin doğrudan değiştirilebildiği ve bunun sonucudunda da admin yetkilerine erişime kadar gidilebildiği, bunun sonucunda da oluşan zafiyetin kullanıcıları silme gibi sonuçlara yol açabileceği PoC adımlarıyla kanıtlanmıştır.

Durum 4: User role can be modified in user profile

Hedef sitenin login isteğinin yanıtında yer alan “roleid” değişkeninin değiştirilerek admin rolüne erişimin sağlanabildiği ve bunun sonucunda da oluşan zafiyetin kullanıcıları silme gibi sonuçlara yol açabileceği PoC adımlarıyla kanıtlanmıştır.

Durum 5: URL-based access control can be circumvented

Test edilmesi istenen admin paneline dışarıdan X-Original-Url başlığı eklenerek ve ilgili path düzenlenerek erişim sağlanabildiği, bunun sonucunda da oluşan zafiyetin kullanıcıları silme gibi sonuçlara yol açabileceği PoC adımlarıyla kanıtlanmıştır.

Durum 6 : Method-based access control can be circumvented

Verilen admin bilgileri kullanılarak gözlemlenen ilgili isteklerin normal kullanıcı hesabı kullanılarak da ilgili istek üzerinde çeşitli ekleme ve değiştirmeler yapılarak admin rolüne yükseltilebildiği, bunun sonucunda da oluşan zafiyetin kullanıcıları silme, rolünü yükseltme gibi sonuçlara yol açabileceği PoC adımlarıyla kanıtlanmıştır.

4. Risk Seviyesi

Risk Seviyesi	Kritik
CVSS v3.1 Skoru	9.4
CVSS v3.1 Vektörü	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L
CWE	CWE-285: Improper Authorization

5. Etki

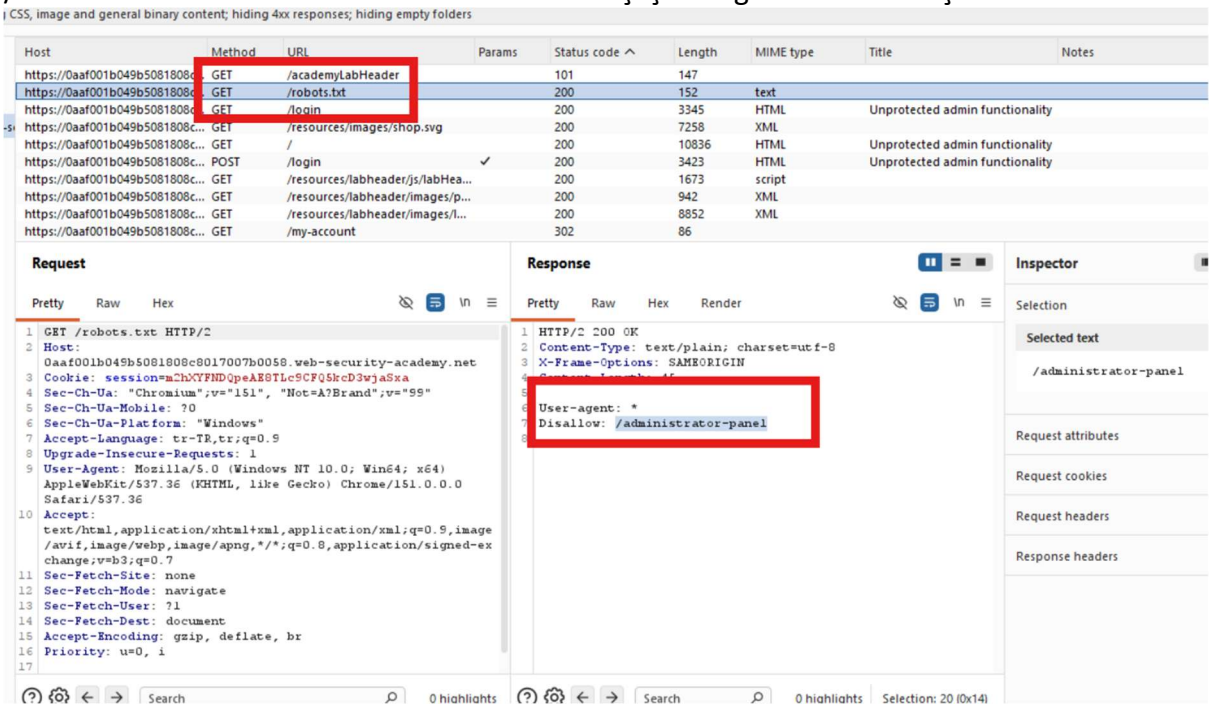
Zafiyetlerin istismar edilmesi durumunda, yetkisiz bir kullanıcı uygulamanın yönetici işlevlerine erişebilmektedir. Bu durum, yönetim panelindeki tüm ayrıcalıklı işlemlerin (kullanıcı hesaplarını silme, roller üzerinde değişiklik yapma vb.) yetkisiz kişilerce gerçekleştirilebilmesi anlamına gelir.

Dikey yetki yükseltmenin en doğrudan sonucu, saldırganın kendisini yönetici seviyesine çıkararak sistem üzerinde tam kontrol elde edebilmesidir. Bu, kullanıcı verilerinin gizliliği ve bütünlüğü açısından kritik bir risk oluşturur; hesapların silinmesi/değiştirilmesi, hassas verilere erişim ve uygulamanın yönetsel işlevlerinin kötüye kullanılması gibi ağır sonuçlara yol açabilir. Erişim kontrolü zafiyetleri, gerçek dünyada en sık karşılaşılan ve en yüksek etkili güvenlik açıklarından biridir (OWASP Top 10 — A01: Broken Access Control).

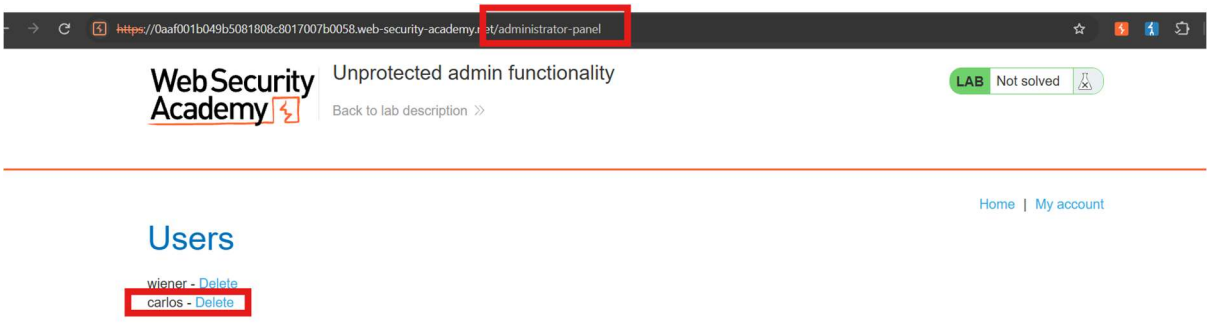
6. Proof Of Concept

Durum 1: Unprotected admin functionality

Hedef sitenin admin işlemleri ile ilgili özellikleri test edilmiştir. Bu testler esnasında /robots.txt uzantısı ile birlikte sunucu hakkında çeşitli bilgiler elde edilmiştir:



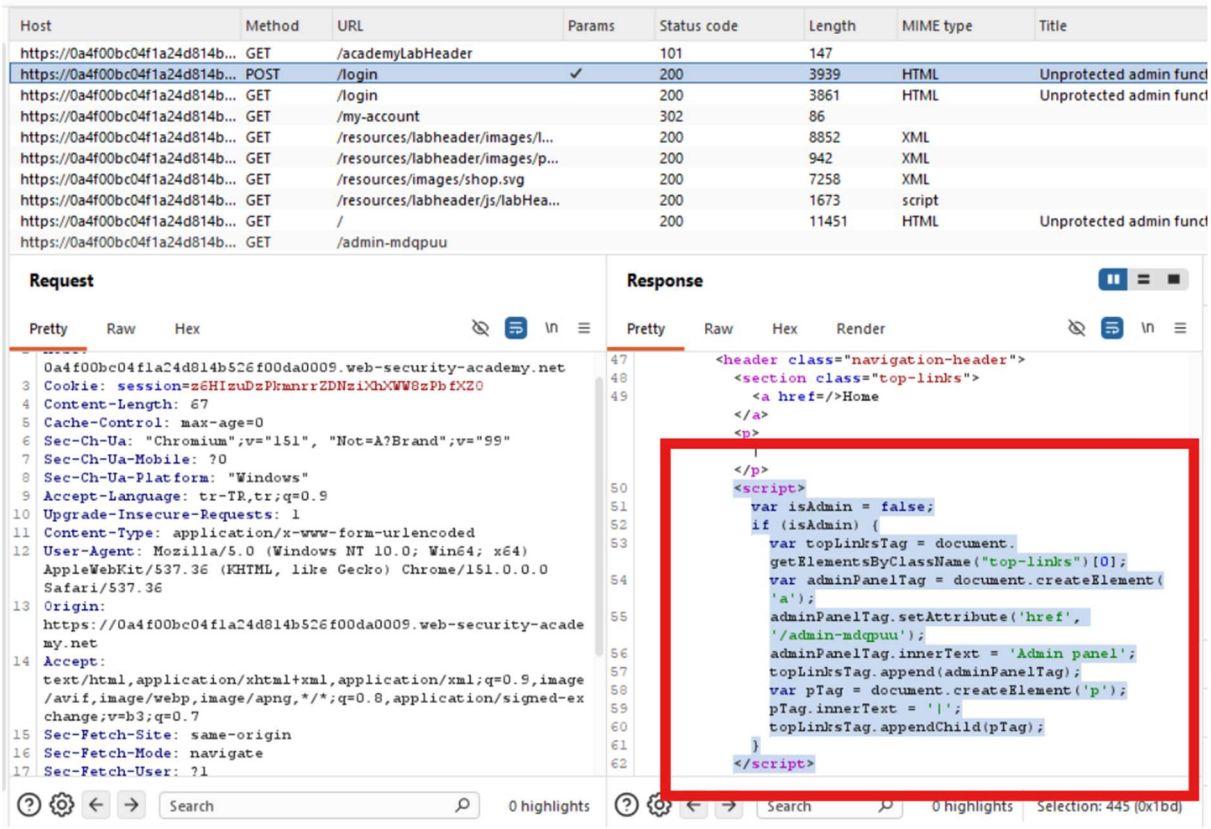
Burada yanıtta “Disallow: /administrator-panel” metni ile karşılaştırılmıştır. Buradaki yönlendirilmeye gidilmemesi istensede bu yönlendirmeyi test ettiğimizde doğrudan admin panele erişim sağlanabilmektedir. Bu sayede de yer alan kullanıcılar silinebilmektedir.



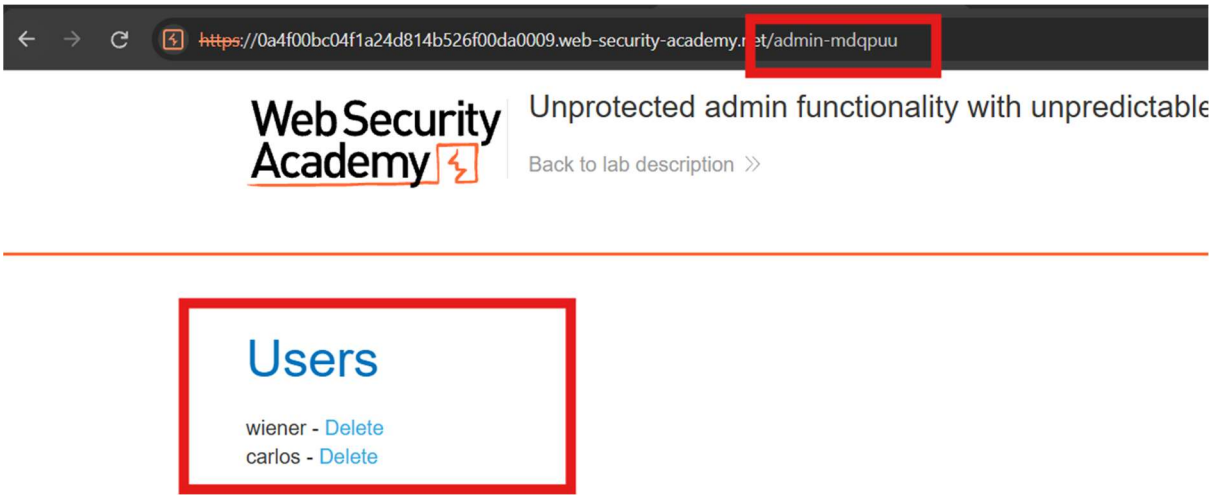
Doğrudan bu panele erişebilmek ve herhangi bir admin giriş işlemi yapmadan admin işlemlerinin yapılabildiği kanıtlanmıştır.

Durum 2 : Unprotected admin functionality with unpredictable URL

Hedef sitenin login sayfasının yanıtı incelendiğinde <script></script> etikekitinin içinde admin sayfasıyla ilgili bir yönlendirme işlevi tespit edilmiştir.

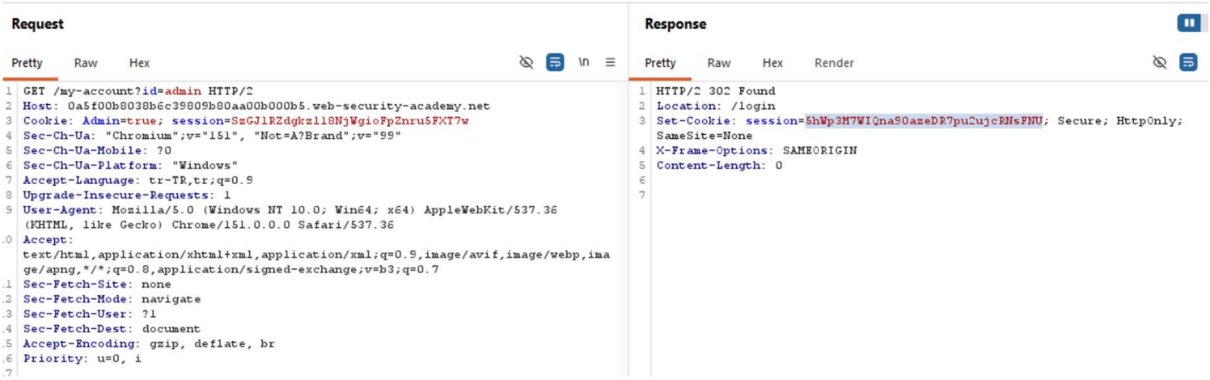


Bu kodun içinde yer alan /admin-mdqpuu yönlendirilmesi test edildiğinde ise doğrudan admin panele erişilebilmektedir. Bu sayede de yer alan kullanıcılar silinebilmektedir. Doğrudan bu panele erişebilmek ve herhangi bir admin giriş işlemi yapmadan admin işlemlerinin yapılabildiği kanıtlanmıştır.



Durum 3 : User role controlled by request parameter

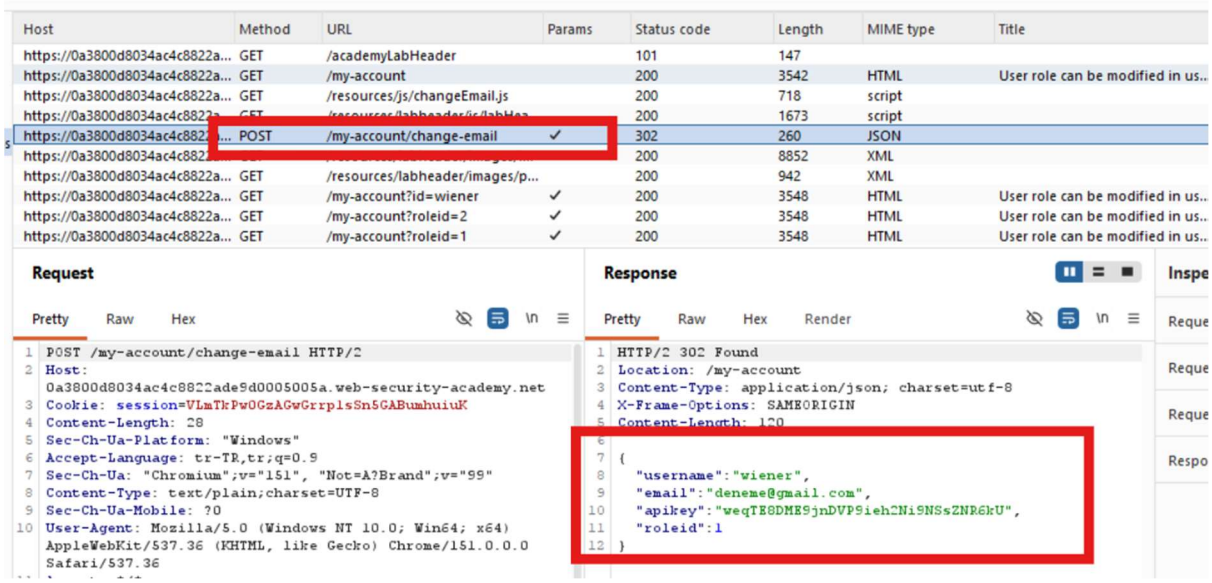
Verilen kimlik bilgileriyle hedef siteye giriş yapılıp ilgili istek Burp'te incelendiğinde "Cookie: Admin=false" değişkeni gözlemlenmiştir. Bu değişken true olarak değiştirildiğinde ve "/my-account?id=wiener" kısmındaki id değeri de admin olarak değiştirildiğinde cevap 302 found alınmıştır.



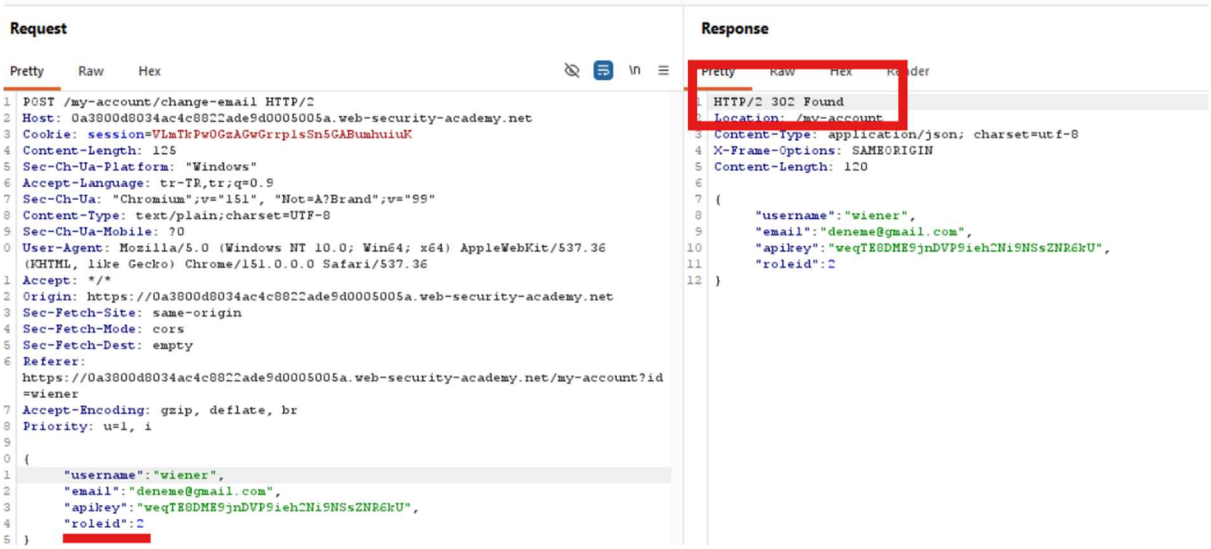
Bu adımdan sonra /admin yönlendirilmesi de aynı şekilde test edildiğinde cevap 302 found alınmıştır. Bunun ardından tekrar ilgili sitede admin paneline erişim denendiğinde başarıyla erişilmiş ve herhangi bir admin giriş işlemi yapmadan admin işlemlerinin yapılabildiği kanıtlanmıştır.

Durum 4 : User role can be modified in user profile

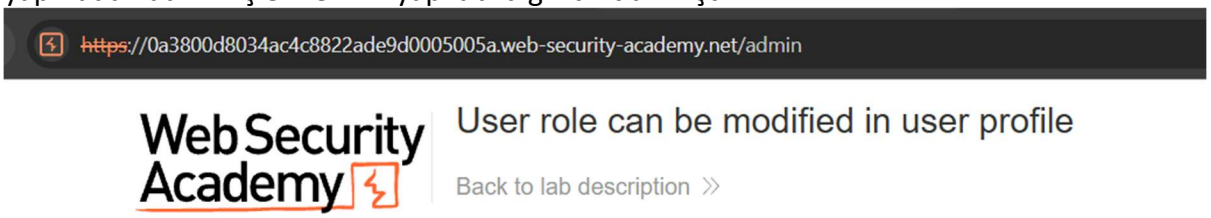
Verilen kimlik bilgileriyle hedef siteye giriş yapılıp email güncelleme fonksiyonu ile ilgili istek Burp'te incelendiğinde yanıtta birden fazla değişken ile karşılaşılmıştır:



Burada yer alan roleid değişkeni üzerinde değişiklik yapılıp roleid: 2 olarak gönderildiğinde yanıt 302 dönmüştür.



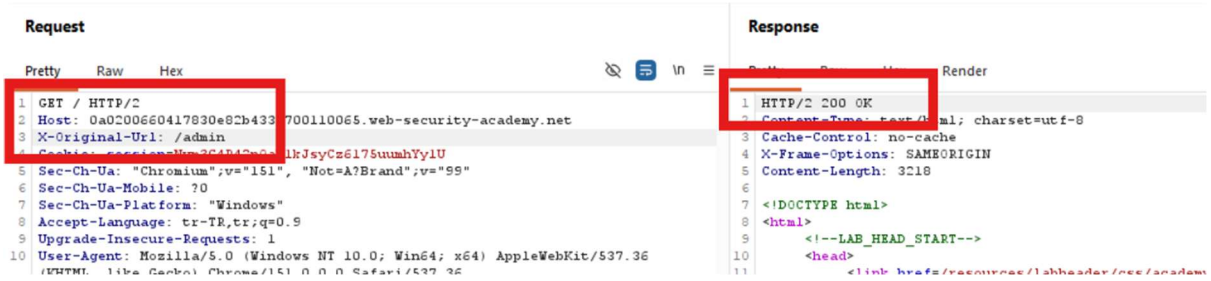
Bunun ardından /admin uzantısına erişim yapılabilmekte olup herhangi bir admin giriş işlemi yapmadan admin işlemlerinin yapılabildiği kanıtlanmıştır.



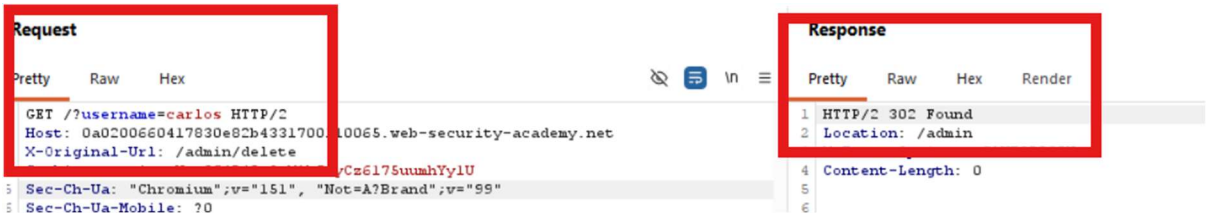


Durum 5 : URL-based access control can be circumvented

Hedef sitenin admin panelinde istenen test doğrultusunda doğrudan erişim denendiğinde 403 yetki hatası alınmaktadır. İlgili isteğe X-Original-Url başlığı eklendip path'deki admin yazısı kaldırıldığında (/admin yazısı engelleniyor) 200 ok yanıtı döndürüldüğü ispatlanmıştır.

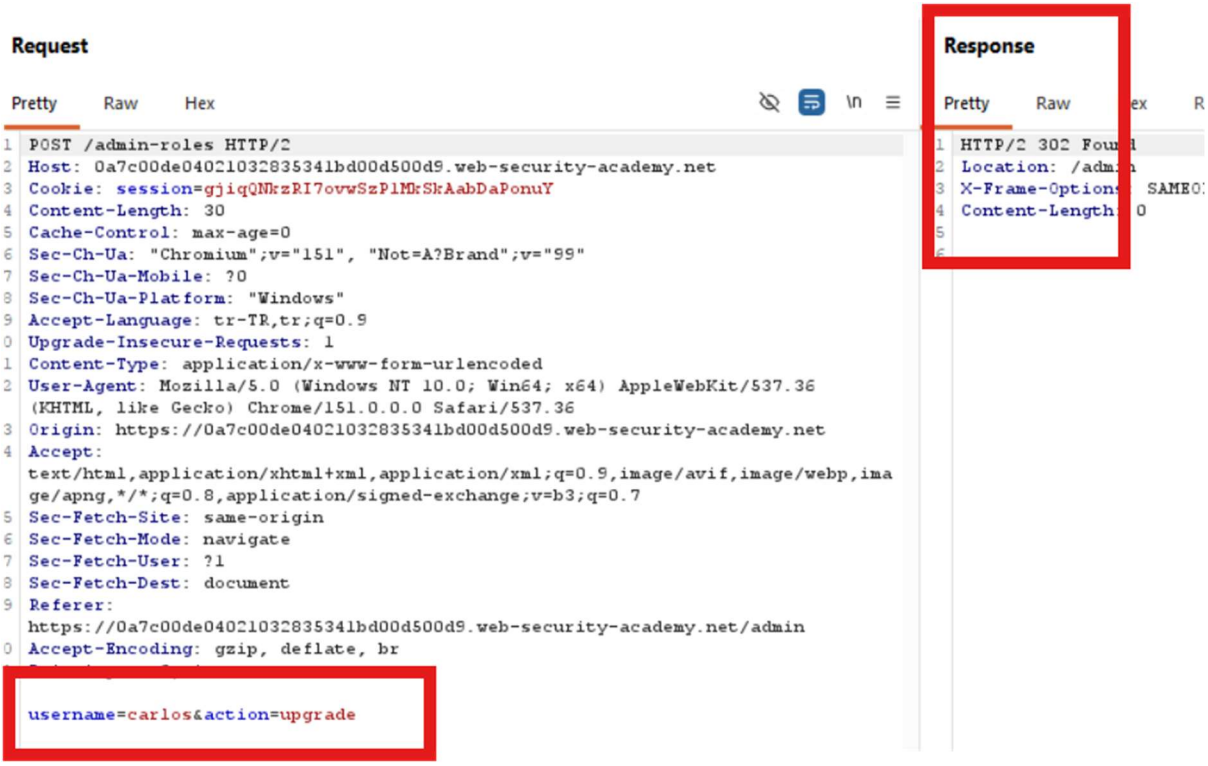


Test edilmesi istenen silme işlemi için path'de admin yazısı olmadan doğrudan kullanıcı yönlendirmesi, X-Original-Url etiketinde ise /admin/delete yönlendirmesi kullanılarak istek yollanmış ve kullanıcının başarıyla silinebildiği kanıtlanmıştır.

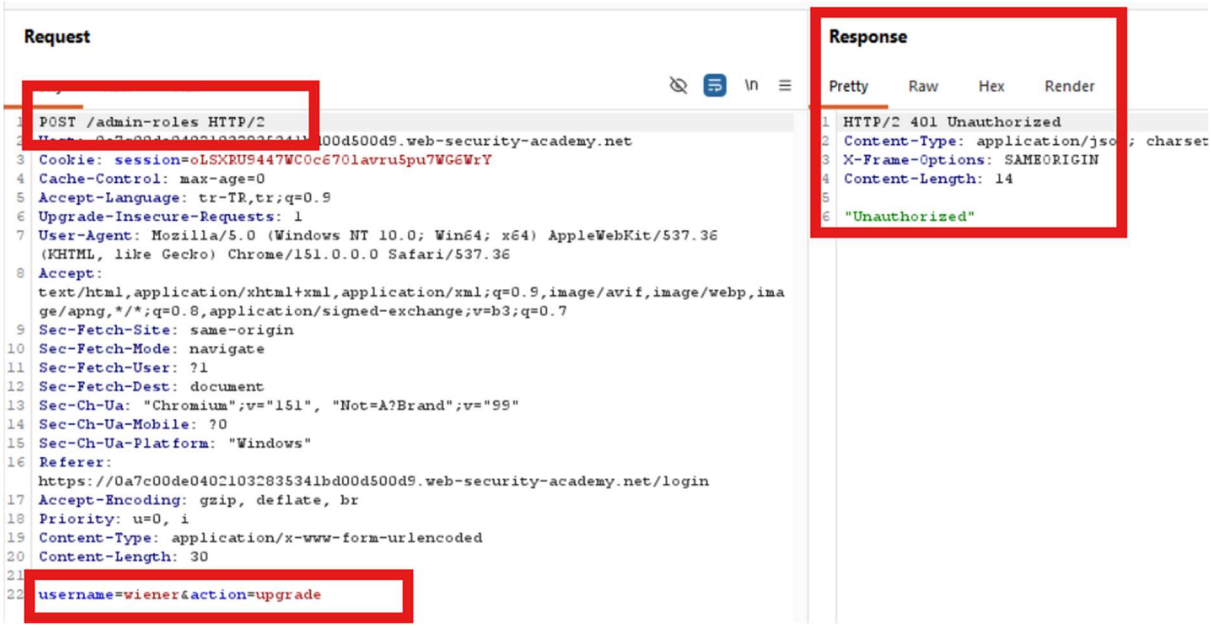


Durum 6 : Method-based access control can be circumvented

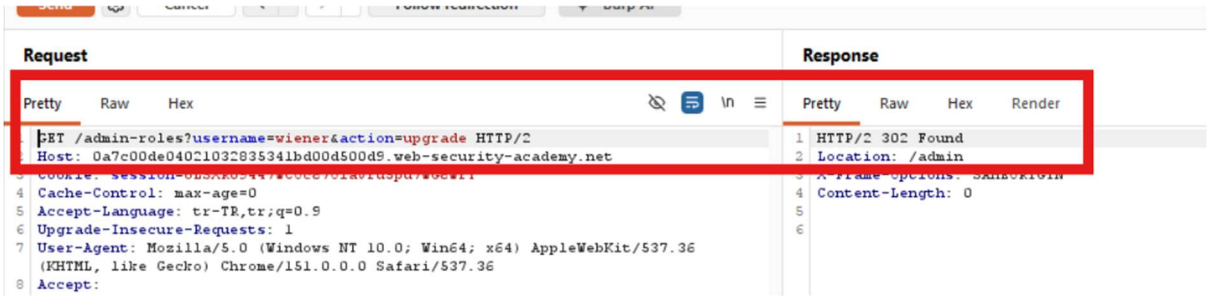
Verilen bilgilerle admin hesabı incelendiğinde rol yükseltme metodunun dışarıdan değiştirilebildiği gözlemlenmiştir.



Normal kullanıcının hesabına giriş yapılıp /my-account isteği Burp Repeater'de username ve action değişkenlerinin eklenmesi ve metodun değiştirilmesi ile birlikte erişim sağlanabildiği kanıtlanmıştır.



Şekil 1: Post metodu ile erişim engelleniyor



Şekil 2: Metod değiştirildiğinde erişim başarılı

Bu sayede normal kullanıcı hesabı admin rolüne yükseltilebilmektedir.

7. Çözüm Önerisi

Hassas işlevlere uygun erişim kontrolü (yetkilendirme) uygulanmalıdır. Yönetim paneli gibi ayrıcalıklı işlevler, yalnızca URL'nin gizli/tahmin edilemez olmasına güvenmemeli; her istekte kullanıcının oturumu ve rolü (ör. admin yetkisi) sunucu tarafında doğrulanmalıdır. Yetkisiz bir kullanıcının isteği, URL'yi bilse dahi reddedilmelidir.

Hassas yollar robots.txt içinde listelenmemelidir. robots.txt herkese açık bir dosyadır; içine yazılan Disallow yolları saldırgana ipucu verir. Gizli tutulması gereken yollar bu dosyada belirtilmemeli, bunun yerine arama motoru indekslemesi gerekiyorsa sayfa/response seviyesinde X-Robots-Tag: noindex ya da meta etiketi kullanılmalıdır.

İstemci tarafı değerlere güvenilmemelidir. Kullanıcının rolü/yetkisi; çerez (Admin=true), istek parametresi ya da profil alanı (roleid) gibi kullanıcının değiştirebileceği değerlerden

okunmamalı, sunucu tarafında güvenli biçimde saklanmalıdır. Profil güncelleme gibi işlemlerde yalnızca güncellenmesine izin verilen alanlar kabul edilmeli (mass assignment engellenmeli).

Erişim kontrolü tek bir yola veya HTTP metoduna bağlanmamalıdır. Yetki denetimi, isteğin URL biçiminden (X-Original-URL vb. başlıklar dahil) ve metodundan (GET/POST) bağımsız olarak, her ayrıcalıklı işlevde tutarlı biçimde uygulanmalıdır.

8. Sonuç

Yapılan testler sonucunda, hedef uygulamanın yetki kontrollerinin altı farklı biçimde atlatılabildiği ve yetkisiz bir kullanıcının yönetici ayrıcalıklarına erişerek kullanıcı silme dahil ayrıcalıklı işlemler gerçekleştirebildiği tespit ve kavram kanıtı ile doğrulanmıştır. Zafiyetlerin temelinde, yetkilendirmenin sunucu tarafında, her istek için ve kullanıcının gerçek rolüne göre doğrulanmaması; bunun yerine gizlilik (tahmin edilemez URL), istemci tarafı değerler (çerez/parametre), ya da tek bir yola/metoda bağlı kontrollere güvenilmesi yatmaktadır. Zafiyet, sistemin tümüyle ele geçirilmesine kadar ilerleyebilecek etkisi nedeniyle yüksek risk seviyesinde değerlendirilmiş olup, önerilen önlemlerin uygulanarak ivedilikle giderilmesi tavsiye edilmektedir.